

Halden Distribution Ltd. — Risk register and methodology

Version: v0.1 · **Owner:** Managing Director (accountable) · **Maintained by:** IT Lead **Date:** 2026-10-02 · **Review:** monthly at the management meeting

The register itself is **empty**, and that is the honest state. No risk has been formally assessed yet; the first population will be the CIS IG1 gaps once the assessment has run. This document records the **methodology** — how a risk is written, scored, owned and treated — so the register can be filled consistently, and it describes what will populate it. Halden Distribution Ltd. is a fictional 85-user company used for a home-lab portfolio.

1. Why a risk register

The monthly report tells management what happened. The risk register tells them what could happen, how bad it would be, who owns it and what is being done. Without it, IT reports activity but the business never makes a conscious decision about what to accept. The register is where a technical gap becomes a business decision with an owner.

2. How a risk is written

Format: *"If... then ... resulting in ..."* — so a non-technical reader can understand the exposure without the technology.

Example of the **form** (not a real Halden risk — this is a worked illustration of the shape only):

"If a departing employee's account is not disabled promptly, then a former member of staff could still reach company data, resulting in a data-protection breach and a supplier-questionnaire failure."

The register lives in `data/risk-register.csv`. Its columns are: `risk_id`, `risk_statement`, `likelihood`, `impact`, `score`, `business_owner`, `existing_controls`, `treatment`, `actions`, `residual_score`, `review_date`, `source`.

3. How a risk is scored

Score = likelihood × impact, using a simple 3×3 scale a small company will actually use consistently:

	Impact: minor	Impact: moderate	Impact: major
Likelihood: likely	medium	high	high
Likelihood: possible	low	medium	high
Likelihood: unlikely	low	low	medium

Impact is judged in business terms — money, legal or regulatory exposure, customer trust, the ability to trade — never in technical severity alone. A server that is only reachable from the lab is not "major" just because it is old.

Initial score is the exposure as it stands today, with existing controls in place. ****Residual score**** is the exposure expected after the planned actions. Both are recorded, because the difference between them is what justifies spending money.

4. Ownership — the rule that matters

A business risk is owned by a business person, never by IT. The `business_owner` column is where this is enforced. IT can own the *action* that reduces a risk; only the business can own the *acceptance* of it. If the only owner available is the IT Lead, the risk is either not a business risk or the business is not engaged — and that is itself a finding worth raising.

Risk area	Typical business owner
Loss of customer/order data	Operations or Managing Director
Financial data or fraud exposure	Finance
Employee data or HR process	HR
Service availability and trading downtime	Operations
Reputation and supplier questionnaires	Managing Director

5. Treatment options

Treatment	Means	When
Mitigate	reduce the likelihood or the impact with a control	the usual answer for a fixable gap
Accept	knowingly live with it	when the cost of control outweighs the risk — recorded, with a review date
Transfer	move it (insurance, contract, outsource)	where insurance or a supplier is the right vehicle
Avoid	stop doing the activity	rare, but sometimes correct

An **accepted** risk is not a forgotten risk: it keeps an owner, a reason and a review date.

6. What will populate the register (first pass)

1. **CIS IG1 gaps** — every safeguard scored below 3 in the assessment becomes a candidate risk.

Control 14 (security awareness) is the largest expected gap and the clearest business risk, because it underpins phishing — the same controls the insurance questionnaire asks about.

1. **P3 findings** — Active Directory security assessment findings not fully remediated.
2. **P4 findings** — unsupported Windows 10 devices and any endpoint exceptions.
3. **P5 findings** — vulnerability exceptions and any high-tier remediation that slipped.
4. **P8 findings** — anything the DR drill exposed, and the dependency on a real off-site copy.
5. **P7 tabletop actions** — gaps the incident-response exercise revealed.

Each entry is written in the *If ... then ...* form, scored, given a **business** owner and a treatment, and tied to an action with a due date.

7. The register

The register is maintained in `data/risk-register.csv`. **It is empty today.** No row is added until a risk has genuinely been assessed — the file deliberately contains only its header, so nobody can mistake a template row for a real risk.

ID	Risk	Likelihood	Impact	Score	Business owner	Treatment	Residual	Review
(empty)								

8. How the register is used

- **Monthly:** the top risks feed section 4 of the monthly IT report, each with a ****recommended decision**** for management — accept, mitigate, fund or defer.
- **Weekly at CAB:** any change that would alter a risk's score is discussed with the affected risk owner.
- **Quarterly:** the whole register is reviewed with the owners and scores are re-estimated against the latest CIS IG1 assessment.

9. Why the register is not filled with plausible-looking examples

It would be easy to invent ten convincing risks for a fictional company. It would also be dishonest, and it would teach the wrong habit: a risk register is only worth having if every entry reflects a real, assessed exposure with a real owner. The register fills as the projects run, and the count of open risks is reported truthfully — today, that count is zero.